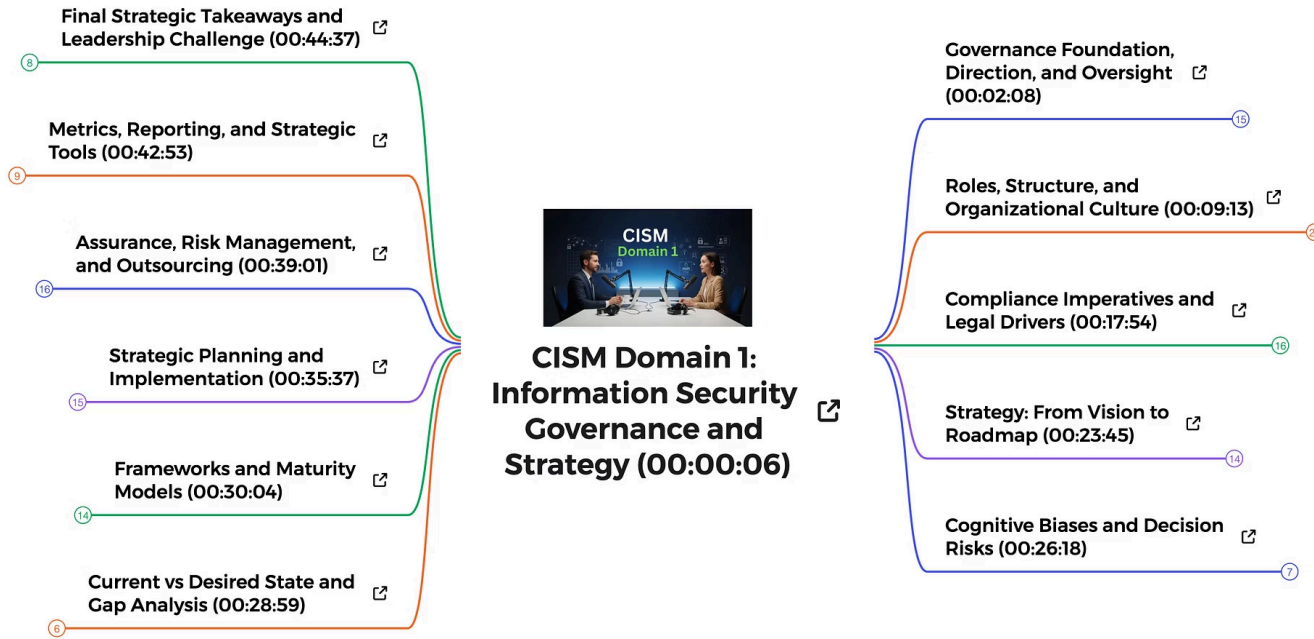


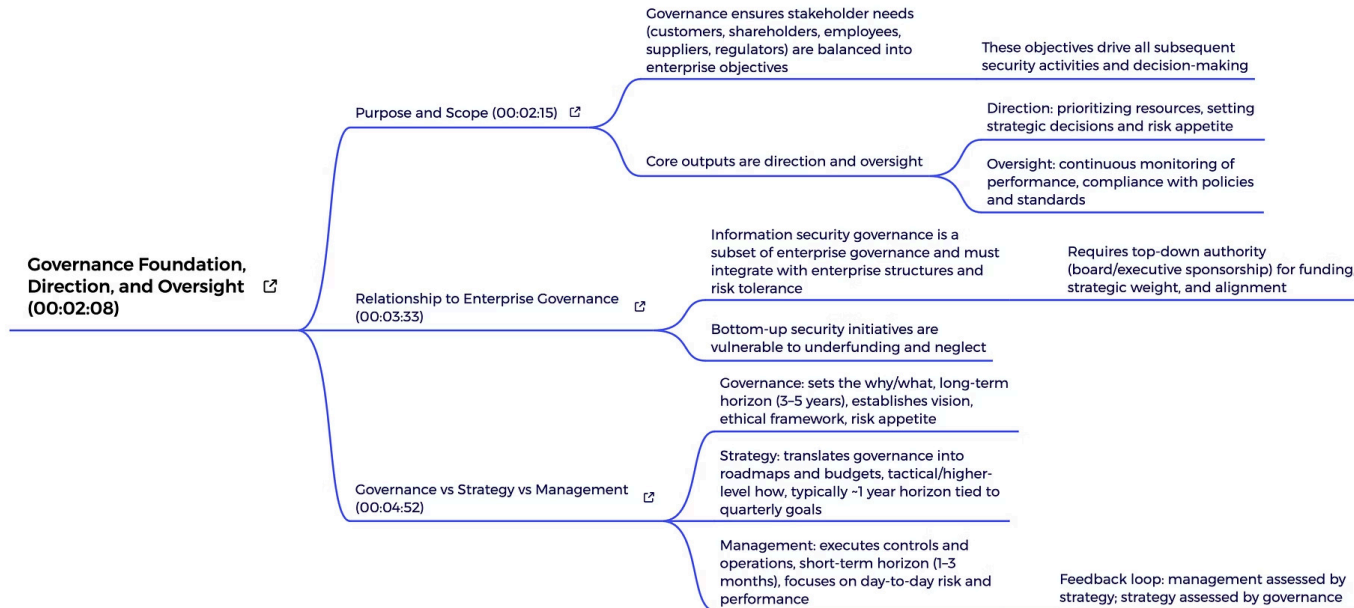


CISM Domain 1: Information Security Governance and Strategy

A comprehensive deep-dive into the foundational principles of information security governance and strategic planning. This domain covers the full spectrum of security leadership — from governance structures and organizational culture to compliance imperatives, risk management, and strategic roadmaps — equipping security professionals with the knowledge to align security programs with enterprise objectives.

- Governance Foundation
- Roles & Culture
- Compliance & Legal
- Strategy & Roadmap
- Risk & Assurance

Governance Foundation, Direction, and Oversight



Purpose & Scope

Governance ensures stakeholder needs — customers, shareholders, employees, suppliers, and regulators — are balanced into enterprise objectives. Core outputs are **direction** and **oversight**: setting strategic priorities and continuously monitoring performance and compliance.

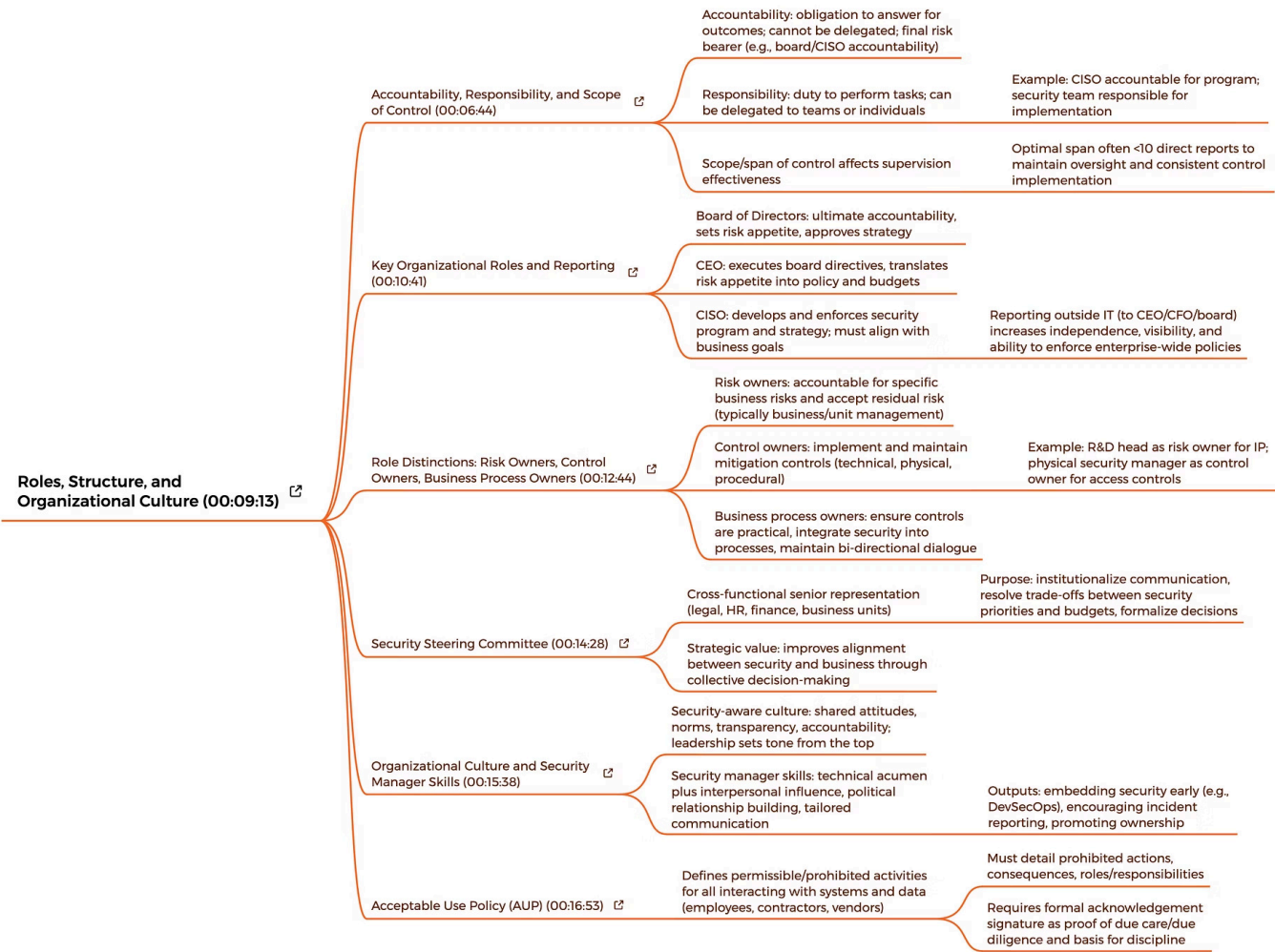
- Top-down authority (board/executive sponsorship) is essential for funding, strategic weight, and organizational alignment.

Governance vs. Strategy vs. Management

- Governance** sets the why/what with a long-term horizon (3–5 years): vision, ethical framework, risk appetite
- Strategy** translates governance into roadmaps and budgets — tactical/higher-level, typically 1-year horizon tied to quarterly goals
- Management** executes controls and operations on a short-term basis (1–3 months), focusing on day-to-day risk and performance

Feedback loop: management is assessed by strategy; strategy is assessed by governance.

Roles, Structure, and Organizational Culture



Accountability & Control Scope

Accountability cannot be delegated — final risk rests with the board/CISO. Responsibility to perform tasks can flow to individuals or teams. Span of control directly affects supervisory effectiveness and reporting structures.

Security Steering Committee

A cross-functional senior body (legal, HR, finance, business units) that institutionalizes communication, resolves trade-offs between security priorities and budgets, and formalizes decisions across the enterprise.

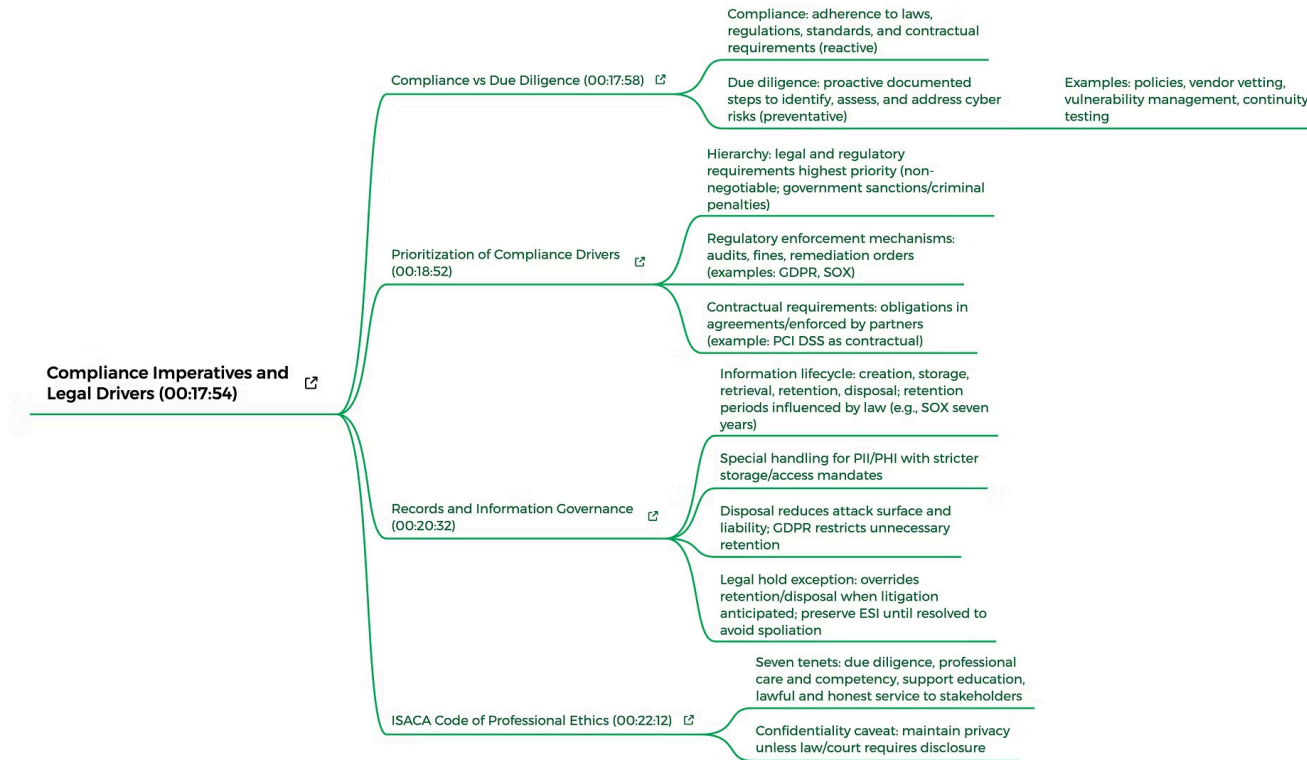
Key Organizational Roles

The Board sets ultimate accountability and approves strategy. The CISO defines and enforces the security program. Risk Owners own specific business risks; Control Owners manage technical, physical, and procedural mitigations.

Culture & Acceptable Use

Security-aware culture embeds shared attitudes, norms, transparency, and accountability. AUPs define permissible/prohibited activities for all interacting with systems, requiring formal acknowledgment as proof of due diligence.

Compliance Imperatives and Legal Drivers



Compliance vs. Due Diligence

Compliance is reactive adherence to laws, regulations, standards, and contractual requirements. **Due diligence** is proactive — documented steps to identify, assess, and address cyber risks before an incident occurs. Examples include policies, vendor vetting, vulnerability management, and continuity testing.

Prioritization of Compliance Drivers

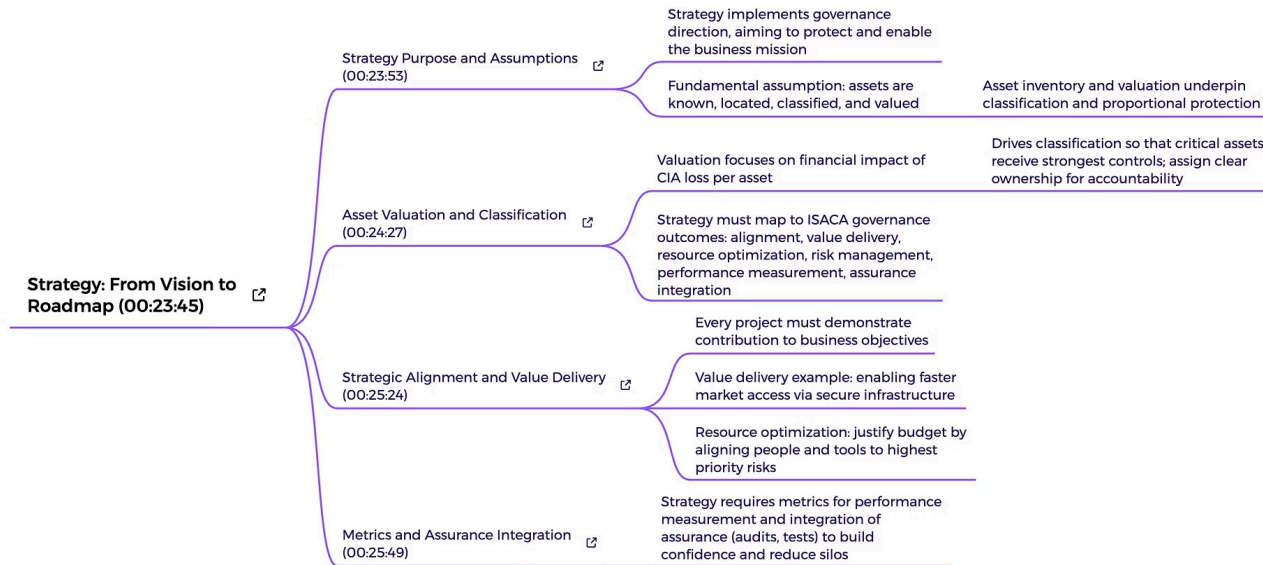
Legal and regulatory requirements take highest priority — government sanctions and criminal penalties are non-negotiable. Regulatory enforcement mechanisms include audits, fines, and remediation orders (e.g., GDPR, SOX). Contractual obligations enforced by partners (PCI DSS, SOC 2) follow closely.

Records & Information Governance

- Information lifecycle: creation, storage, retrieval, retention, disposal — retention periods influenced by law (e.g., SOX 7-year rule)
- Special handling for PII/PHI under stricter governance and compliance mandates
- Disposal reduces attack surface and liability; GDPR restricts unnecessary retention
- Legal hold overrides retention/disposal when litigation is anticipated

ISACA Code of Professional Ethics: Serve stakeholders with due diligence, maintain confidentiality, and disclose only when legally required.

Strategy: From Vision to Roadmap



Strategy Purpose & Assumptions

Strategy implements governance direction — to protect and enable the business mission. The fundamental assumption: **assets are known, located, classified, and valued**. Asset inventory and valuation underpin classification and proportional protection. Critical assets receive the strongest controls with clear ownership accountability.

Asset Valuation & Classification

Valuation focuses on the financial impact of CIA loss per asset, mapped to ISACA governance outcomes: alignment, value delivery, resource optimization, risk management, performance measurement, and assurance integration. Classification drives control proportionality — the more critical the asset, the stronger the controls required.

Strategic Alignment & Value Delivery

Every project must demonstrate a contribution to business objectives. Value delivery examples: enabling faster market access via secure infrastructure. Resource optimization: justify budget by aligning people and tools to the highest-priority risks across the enterprise portfolio.

Metrics & Assurance Integration

Strategy requires performance metrics and integration of assurance activities — audits and testing — to build confidence and reduce operational silos. Metrics validate that controls are effective, that governance direction is being followed, and that the security program delivers measurable business value.